MODULE 22 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Compliance Automation and Patch Management

Evaluate every resource continuously, remediate automatically, find vulnerabilities everywhere code runs, and patch across the organisation.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 22 of 52

admin@sthithapragna.com

Compliance is a **loop**: evaluate, report, remediate, and evaluate again, without a person in the middle.

AWS Config building blocks

PIECE	WHAT IT DOES
Managed rules	Hundreds of prebuilt checks, such as encrypted volumes
Custom rules	Your logic, in Lambda or Guard policy language
Conformance packs	Rules and remediations deployed as one unit
Organisation rules and packs	Deployed to every account from one place
Remediation	Systems Manager Automation runbooks, manual or automatic
Aggregator	Compliance across accounts and Regions in one view

ON THE EXAM

A framework's checks plus fixes, everywhere at once: an organisation conformance pack.

Security Hub CSPM

- **Standards:** Foundational Best Practices, CIS, PCI DSS, NIST 800-53.
- **Central configuration** sets standards and controls per OU from the delegated admin.
- **Automation rules** change finding severity or status as findings arrive.
- **Remediation** through EventBridge to Automation runbooks or Lambda.
- **Findings** feed the new Security Hub for correlation.

> ON THE EXAM
>
> Automation rules triage findings. They do not fix resources; EventBridge and runbooks do.

What Amazon Inspector scans

TARGET	HOW
EC2 instances	SSM agent, or agentless from EBS snapshots
ECR container images	On push and continuously as new CVEs appear
Lambda functions	Packages, and optionally function code
Code repositories	Code security: source, dependencies, IaC
EC2 operating systems	CIS benchmark assessments

ON THE EXAM

Inspector Classic support ended 20 May 2026. Any answer naming it is stale.

Prioritising vulnerabilities

- **Inspector score** adjusts CVSS for your environment, such as network reachability.
- **EPSS** estimates the chance of exploitation in the wild.
- **Exploit available** flags known public exploit code.
- **Suppression rules** hide accepted risks; **SBOM export** lists components.

> ON THE EXAM
>
> Patch first what is reachable and likely to be exploited, not simply the highest CVSS.

Patch Manager essentials

CONCEPT	MEANING
Patch baseline	Which patches are approved, per operating system
Auto-approval delay	Approve, say, critical patches 7 days after release
Scan or install	Report compliance only, or install and reboot
Patch policy	One Quick Setup policy for many accounts and Regions
Rate control	Concurrency and error thresholds limit blast radius

ON THE EXAM

Organisation-wide patching from one configuration: a Quick Setup patch policy.

Patch in place, or replace?

PATCH IN PLACE

Patch Manager

- Long-lived instances
- Install on schedule, reboot if needed
- Compliance reported per node
- Suits stateful or legacy servers

REPLACE WITH NEW IMAGE

Image Builder and redeploy

- Immutable, auto-scaled fleets
- Build and test a new AMI or image
- Roll out with instance refresh
- No drift between nodes

THE TIEBREAKER

Auto Scaling groups and containers: rebuild the image. Pets that must stay up: patch in place.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Framework checks and fixes in every account	Organisation conformance pack
Patch everything, many accounts and Regions	Quick Setup patch policy
No agent possible on the instance	Inspector agentless scanning
Flaws in source code before deployment	Inspector code security
Too many findings, adjust per environment	CSPM automation rules
Critical CVE found, fix automatically	EventBridge to a patch runbook

ON THE EXAM

Detect with Config, CSPM or Inspector. Act with EventBridge and Systems Manager.

> Meridian Freight's payments accounts must demonstrate continuous PCI DSS compliance. Certain violations, such as S3 buckets without default encryption, must be fixed automatically.
>
> The same checks must apply to every account in the Payments OU, including new ones.

What should the solutions architect implement?

A Quarterly manual reviews using the AWS Config console

B An organisation conformance pack for PCI DSS deployed to the Payments OU, with automatic remediation using Systems Manager Automation runbooks

C Security Hub CSPM automation rules that mark findings as resolved

D GuardDuty enabled in every payments account

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Quarterly reviews

Neither continuous nor automatic.

B Conformance pack with remediation

Continuous checks, automatic fixes, deployed to the OU.

C Automation rules

Change the finding's status; the bucket stays unencrypted.

D GuardDuty

Detects threats, not configuration compliance.

THE SIGNAL

Continuous, framework-mapped, self-fixing, OU-wide: an organisation conformance pack.

> Meridian Freight runs long-lived Linux and Windows EC2 instances across 80 accounts in six Regions. Critical and important security patches must be installed weekly, seven days after release.
>
> The operations team wants one configuration rather than setup in each account and Region.

What should the solutions architect recommend?

A. A maintenance window and patch group created in each account and Region

B. Amazon Inspector with automatic patching enabled

C. A Quick Setup patch policy from the management account targeting the organisation, with baselines auto-approving those patches after seven days

D. Rebuild every instance from a new AMI each week

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Per-account windows

Works, but 480 configurations to build and keep in step.

B Inspector

Finds vulnerabilities; it does not install patches.

C Patch policy

One configuration for every account and Region, with a 7-day approval delay.

D Weekly rebuilds

Suits immutable fleets, not long-lived servers.

THE SIGNAL

Many accounts and Regions, one configuration: a Quick Setup patch policy.

> Meridian Freight needs continuous vulnerability scanning of its EC2 fleet, its ECR container images and its Lambda functions.
>
> Some EC2 instances are vendor appliances on which the Systems Manager agent cannot be installed, and they must be scanned too.

What should the solutions architect implement?

A. Amazon Inspector with EC2 hybrid scanning, so appliances are scanned agentlessly, plus ECR and Lambda scanning

B. ECR basic scanning, and Inspector Classic for EC2

C. GuardDuty Malware Protection for EC2 and ECR

D. AWS Config rules that check instance software versions

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Inspector hybrid scanning

Agent where possible, EBS snapshots where not; ECR and Lambda too.

B Basic and Classic

Inspector Classic has ended; basic scanning is not continuous.

C Malware Protection

Finds malware, not known vulnerabilities.

D Config rules

Custom version checks, with no vulnerability database.

THE SIGNAL

No agent possible still means Inspector, scanning agentlessly from snapshots.

> Meridian Freight wants to find vulnerable open-source dependencies, hard-coded secrets and insecure infrastructure-as-code templates in its application repositories.
>
> Developers should see results on pull requests, before anything is built or deployed.

What should the solutions architect recommend?

A. Inspector ECR enhanced scanning of built images

B. Security Hub CSPM with the CIS standard

C. AWS Config custom rules

D. Amazon Inspector code security connected to the repositories

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A ECR scanning

Runs after the image is built, too late for this requirement.

B CSPM with CIS

Checks deployed account configuration, not source code.

C Config rules

Evaluate deployed resources, not repositories.

D Inspector code security

Scans source, dependencies, secrets and IaC in the repository.

THE SIGNAL

Before build, in the repository, on pull requests: Inspector code security.

> Meridian Freight's security team receives thousands of Security Hub CSPM findings a day. Many come from sandbox accounts where certain controls are accepted risks, while the same findings in production should be raised to critical.
>
> The team wants this handled automatically as findings arrive.

What should the solutions architect configure?

A. Disable Security Hub CSPM in the sandbox accounts

B. Security Hub CSPM automation rules that suppress the accepted findings in sandbox accounts and raise severity in production

C. A Lambda function that deletes sandbox findings nightly

D. Separate delegated administrators for sandbox and production

◆ PAUSE AND DECIDE

What should the solutions architect configure?

A Disable in sandbox

Loses all visibility, including real problems.

B Automation rules

Adjust status and severity by account as findings arrive.

C Nightly deletion

Custom code, delayed, and destroys evidence.

D Two administrators

One delegated administrator per organisation; does not triage.

THE SIGNAL

Triage findings by context, automatically, at arrival: automation rules.

> When Amazon Inspector reports a critical vulnerability with a known exploit on a long-lived EC2 instance, Meridian Freight wants the instance patched straight away, without waiting for the weekly window.
>
> The response must be automatic and recorded.

What should the solutions architect implement?

A. A Lambda function that terminates the affected instance

B. An email to the instance owner from an SNS topic

C. An EventBridge rule matching critical Inspector findings that starts a Systems Manager Automation runbook running AWS-RunPatchBaseline on the instance

D. An AWS Config rule that marks the instance non-compliant

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Terminate

Destroys a long-lived server instead of fixing it.

B Email the owner

Not automatic.

C EventBridge to patch runbook

Detect, route and act, with the run recorded by Systems Manager.

D Config rule

Reports again; does not patch.

THE SIGNAL

Detector, EventBridge, Systems Manager. The standard automatic response chain.

What to carry out of this module

- **Conformance packs** deploy checks and remediations across OUs.
- **CSPM automation rules triage;** runbooks remediate.
- **Inspector** covers EC2 with or without agent, ECR, Lambda and code.
- **Patch policies** patch the organisation from one configuration.
- **Immutable fleets** get new images, not patches in place.

> ON THE EXAM
>
> Detect with Config, CSPM or Inspector. Route with EventBridge. Act with Systems Manager.